CYBERSECURITY PRACTICAL: MINI PROJECT REPORT

Who Controls What the AI Sees?

Telemetry Integrity in AI-Based Infrastructure Security: An Internal Pentest Perspective

Student Name	Kotra Balaji
Project Area	AI Infrastructure Cybersecurity / Internal Penetration Testing
Project Type	Technical analysis with controlled simulation
Environment in source project	Ubuntu 24.04.4 LTS, Python 3.12.3, NumPy 2.4.4
Date	22 October 2026

Project overview

This project studies whether an internal attacker can weaken AI-based security detection by tampering with the telemetry that the AI receives. It explains the telemetry pipeline, defines safe validation checks, and summarises a reproducible simulation using synthetic events. The focus is the integrity and completeness of security data—not attacking or changing the AI model itself.

Source note: This report follows the structure and concise practical-report style of the supplied reference template. Technical details and simulation findings are based on the uploaded project document, “Who Controls What the AI Sees?” by Kubireddi Nirmala.

1. Aim

To examine how tampering with security telemetry can reduce the effectiveness of AI-based detection, and to compare monitoring approaches that can identify missing or manipulated events.

2. Objectives

• Describe the main components in an AI security telemetry pipeline.

• Identify trust boundaries and common telemetry-integrity weaknesses.

• Define safe, authorised internal-pentest validation checks.

• Compare four monitors against blackout, selective suppression and gradual-throttling scenarios.

• Recommend practical controls based on the simulation results.

3. Introduction

AI-based security tools, including UEBA and machine-learning SIEM analytics, depend on the events collected from endpoints, identity systems and other sources. If events are missing, delayed, altered or attributed to the wrong account, the detection engine may receive an incomplete picture even when its model is functioning correctly.

An internal pentester therefore checks two things: whether the system can detect suspicious activity, and whether an attacker with an internal foothold could influence the evidence used for detection.

4. Threat Model and Scope

Attacker: An insider or an actor using valid credentials who has configuration or write access to one telemetry component. **Goal:** Perform activity while leaving a reduced or misleading trail. **Out of scope:** Live exploitation of production systems, model theft and adversarial attacks directly against the model.

Safety: The source project describes a synthetic simulation. Any real assessment should have written authorisation, use test systems or synthetic events, and avoid deleting production logs or disabling live agents without an approved change window.

5. Telemetry Pipeline and Trust Boundaries

The telemetry pipeline connects event sources to collection, processing, feature generation, AI/UEBA analytics and security response. Every component and service account is part of the internal attack surface.

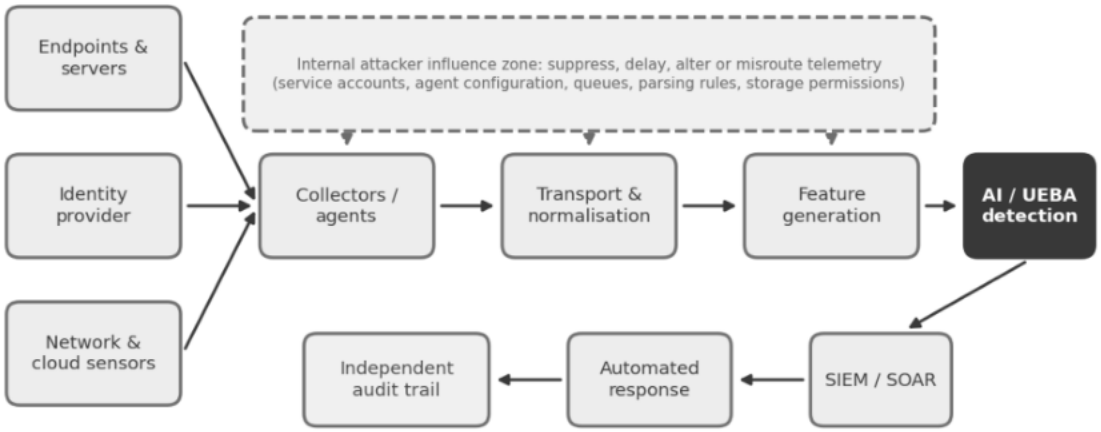


Figure 1. Telemetry pipeline and the area an internal attacker may influence (source project, page 5).

5.1 Key integrity properties

Property	Example failure	Possible effect
Completeness	Events dropped or agent stops reporting	Attacker activity may never reach the model.
Timeliness	Queue backlog or delayed forwarding	Alerts arrive too late.
Authenticity / integrity	Fields altered in transit or storage	Events may appear normal or unreliable.
Attribution	Wrong user, host or timestamp	Behaviour is assigned to the wrong identity.
Correlation	Independent sources cannot be joined	Multi-step activity appears unrelated.

Common weak points include over-privileged service accounts, editable agent configurations, unprotected transport, unaudited parsing changes, mutable storage and excessive automation based on one signal.

6. Internal Pentest Validation Framework

The project proposes safe, evidence-based checks. Tests should verify permissions and expected visibility rather than create real data loss.

Area	Validation question / safe check	Pass criterion
Identity	Review service accounts, ownership and group membership.	Every account has a documented purpose and owner.
Privilege	Review effective read/write/delete/admin permissions.	Roles are separated; unnecessary delete rights are removed.
Collection	In an approved test window, test a non-critical source and measure alert time.	Source loss triggers an alert within the agreed time.
Transport	Review TLS, signing and authenticated forwarding settings.	Events are protected in transit.
Storage	Review index permissions and retention controls.	Evidence is protected from unauthorised changes.
Processing	Review change control for parsing and normalisation rules.	Changes are approved and logged.
Correlation	Trace a synthetic logon across identity and endpoint records.	Missing counterpart events raise an alert.
Recovery	Verify a separate audit trail and restore process.	Independent evidence survives a pipeline compromise.

7. Simulation Design

The supplied experiment models 30 hosts and 20 accounts per host over 14 days. Identity and endpoint sources capture events independently, with small natural loss. An attacker uses a valid account on one target host and tampers with that host’s endpoint telemetry for 12 hours. All data are synthetic; no real user, log or production system is involved.

Four monitors are compared: aggregate event volume, source silence, host-level reconciliation and account-level reconciliation.

8. Scenarios and Monitoring Rules

Scenario	What happens	Purpose
S0 — Clean control	No tampering or attacker activity.	Measure false alarms.
S1 — Source blackout	All endpoint events from the target host are dropped for 12 hours.	Obvious loss of visibility.
S2 — Selective suppression	Only the attacker account's endpoint events are dropped.	Test targeted tampering while total volume stays near normal.
S3 — Gradual throttling	The share of dropped events rises gradually from 0% to 90%.	Test partial loss without a fully silent source.

8.1 Monitor summary

Monitor	Rule
A — Aggregate volume	Alert if total endpoint events drop below 50% of the same-hour median from the previous three days.
B — Source silence	Alert if a host's endpoint source reports nothing for four consecutive hours.
C — Host reconciliation	Across three hours, alert when identity events are present but endpoint events are below 70% of them.
D — Account reconciliation	Across three hours, alert when an account has at least four identity events and zero endpoint events.

These thresholds and scenarios are taken from the source project; they are simulation settings, not universal production thresholds.

9. Simulation Evidence and Results

The source project includes terminal output, a gradual-throttling graph and a summary chart. The figures below are reproduced from the supplied project document.

monitor alerted on the target host during the tampering window.

Terminal

```
$ python3 telemetry_integrity_sim.py
Main run, seed 42  (hours after tampering began; '-' = not detected)
Scenario                Detector                  Detected  First alert  Episodes (d4-14)
-------------------------------------------------------------------------------------
S0 Clean control        A Aggregate volume        n/a       n/a          0
S0 Clean control        B Source silence          n/a       n/a          1
S0 Clean control        C Host reconciliation     n/a       n/a          0
S0 Clean control        D Account reconciliation  n/a       n/a          0

S1 Source blackout      A Aggregate volume        NO        -            0
S1 Source blackout      B Source silence          YES       +3h          2
S1 Source blackout      C Host reconciliation     YES       +0h          1
S1 Source blackout      D Account reconciliation  YES       +1h          15

S2 Selective suppression  A Aggregate volume      NO        -            0
S2 Selective suppression  B Source silence        NO        -            1
S2 Selective suppression  C Host reconciliation   YES       +1h          2
S2 Selective suppression  D Account reconciliation YES      +1h          1

S3 Gradual throttling   A Aggregate volume        NO        -            0
S3 Gradual throttling   B Source silence          NO        -            1
```

Figure 2. Terminal output for the main simulation run (seed 42; source project, page 8).

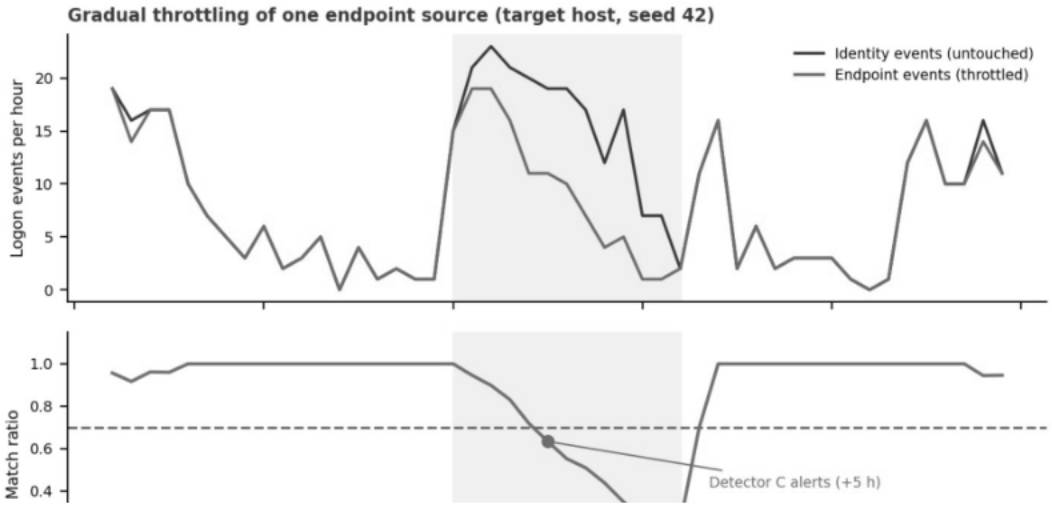


Figure 3. Gradual-throttling reconciliation behaviour and 300-run summary (source project, page 9).

9.1 Results across 300 simulation runs

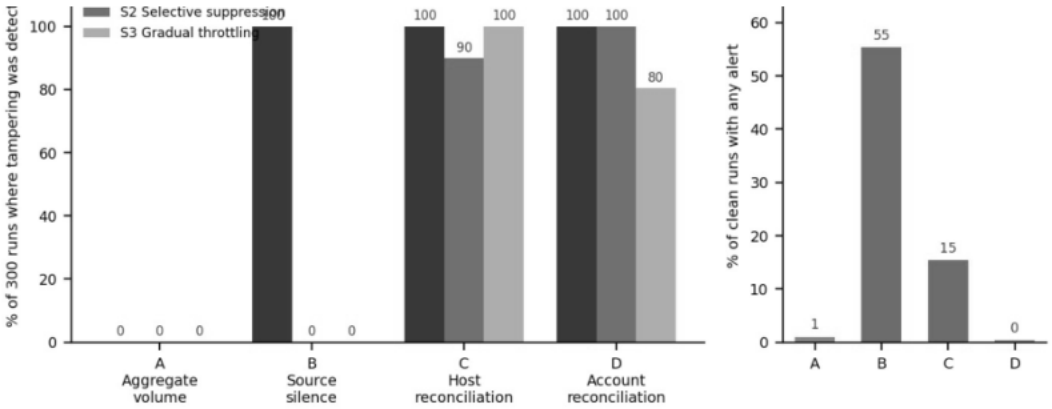


Figure 4. Detection of tampering and false-alarm rates across 300 runs.

Median time to first alert among detected runs was 3 hours for Monitor B on S1; 0 hours for Monitor C on S1; 5 hours for Monitor C on S2 and S3; 0 hours for Monitor D on S1 and S2; and 9 hours for Monitor D on S3.

Figure 4. Detection and false-alarm comparison across 300 runs (source project, page 10).

Monitor	Blackout S1	Selective S2	Throttling S3	Clean runs with alert
A — Aggregate volume	0%	0%	0%	1%
B — Source silence	100%	0%	0%	55%
C — Host reconciliation	100%	90%	100%	15%
D — Account reconciliation	100%	100%	80%	0%

Discussion: Aggregate volume missed all three tampering strategies because one host contributes only a small share of total events. Source-silence detection caught blackout but missed selective and gradual loss, and it produced alerts in 55% of clean runs. Host reconciliation detected all blackout and throttling runs and 90% of selective-suppression runs, but had some false alarms. Account reconciliation had no false-alarm runs and caught all blackout and selective-suppression runs, but detected gradual throttling in 80% of runs.

The source notes that combining host- and account-level reconciliation may reduce misses, but this combined approach was not measured in the reported experiment.

10. Recommended Security Controls

Priority	Control	Reason
P1	Use host- and account-level cross-source reconciliation; group related alerts into one incident.	Detects selective and gradual tampering while reducing alert storms.
P1	Apply least privilege to collectors, processors, feature stores and AI platforms.	Limits misuse of service accounts.
P1	Maintain an independent, append-only or write-once audit path.	Preserves evidence if the main pipeline is compromised.
P2	Alert on agent/collector failure, source disappearance and configuration changes.	Improves visibility-loss detection.
P2	Track expected freshness and volume for each important source.	Highlights delay and throttling.
P3	Require human approval or a second independent signal for high-impact automated actions.	Limits harm from manipulated inputs.
P3	Include telemetry-integrity scenarios in authorised internal pentests.	Tests the data pipeline as part of the attack surface.

11. Limitations

The study uses synthetic data and a simplified model with two sources. It does not model delayed or duplicated events, coordinated failure of multiple sources, or an adaptive attacker. The thresholds are fixed, and no commercial product or production environment was tested. Therefore, the reported percentages demonstrate the simulated mechanism rather than product performance.

12. Conclusion

The project demonstrates that AI-based security depends on trustworthy telemetry. A global volume check may miss targeted manipulation, and a silence rule only detects complete outages. Comparing independent sources is more effective for detecting missing events. Security teams should protect the telemetry pipeline with least privilege, independent audit trails, freshness monitoring and cross-source reconciliation.

References

[1] Kubireddi Nirmala, “Who Controls What the AI Sees? Telemetry integrity in AI-based infrastructure security: an internal pentester’s view, with a simulation study,” technical blog and methodology notes, 22 October 2026 (uploaded project source).
[2] NIST, Artificial Intelligence Risk Management Framework (AI RMF 1.0), 2023.
[3] NIST SP 800-92, Guide to Computer Security Log Management, 2006.
[4] NIST SP 800-207, Zero Trust Architecture, 2020.
[5] MITRE ATT&CK: Valid Accounts (T1078), Impair Defenses (T1562), Indicator Removal (T1070), and Data Manipulation (T1565).